

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **China - Personal Information Protection Law of the People's Republic of China (2021)**

Focal Document URL: <https://digichina.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-2021/>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-chn-pi-pl-2021.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
Article 1	N/A	This Law is formulated, on the basis of the Constitution, in order to protect personal information rights and interests, standardize personal information handling activities, and promote the rational use of personal information.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 2	N/A	The personal information of natural persons receives legal protection; no organization or individual may infringe upon natural persons' personal information rights and interests.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 3	N/A	This Law applies to the activities of handling the personal information of natural persons within the borders of the People's Republic of China. Where one of the following circumstances is present in handling activities outside the borders of the People's Republic of China of personal information of natural persons within the borders of the People's Republic of China, this Law applies as well: 1. Where the purpose is to provide products or services to natural persons inside the borders; 2. Where analyzing or assessing activities of natural persons inside the borders; 3. Other circumstances provided in laws or administrative regulations.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 4	N/A	Personal information is all kinds of information, recorded by electronic or other means, related to identified or identifiable natural persons, not including information after anonymization handling. Personal information handling includes personal information collection, storage, use, processing, transmission, provision, disclosure, deletion, etc.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 5	N/A	The principles of legality, propriety, necessity, and sincerity shall be observed for personal information handling. It is prohibited to handle personal information in misleading, swindling, coercive, or other such ways.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
Article 6	N/A	Personal information handling shall have a clear and reasonable purpose, and shall be directly related to the handling purpose, using a method with the smallest influence on individual rights and interests. The collection of personal information shall be limited to the smallest scope for realizing the handling purpose, and excessive personal information collection is prohibited.	Functional	Intersects With	Purpose Specification	PRI-02.1	Mechanisms exist to ensure data privacy notices identify the purpose(s) for which Personal Data (PD) is collected, received, processed, stored, transmitted and/or shared.	5	
Article 7	N/A	The principles of openness and transparency shall be observed in the handling of personal information, disclosing the rules for handling personal information and clearly indicating the purpose, method, and scope of handling.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
Article 8	N/A	The handling of personal information shall ensure the quality of personal information, and avoid adverse effects on individual rights and interests from inaccurate or incomplete personal information.	Functional	Intersects With	Personal Data (PD) Accuracy & Integrity	PRI-05.2	Mechanisms exist to ensure the accuracy and relevance of Personal Data (PD) throughout the information lifecycle by: (1) Keeping PD up-to-date; and (2) Remediating identified inaccuracies, as necessary.	5	
Article 9	N/A	Personal information handlers shall bear responsibility for their personal information handling activities, and adopt the necessary measures to safeguard the security of the personal information they handle.	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
Article 10	N/A	No organization or individual may illegally collect, use, process, or transmit others' personal information, or illegally sell, buy, provide, or disclose other persons' personal information, or engage in personal information handling activities harming national security or the public interest.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
Article 11	N/A	The State establishes a personal information protection structure, to prevent and punish acts harming personal information rights and interests, strengthen personal information protection propaganda and education, and promote the creation of a good environment for personal information protection, with joint participation from government, enterprise, relevant social organizations, and the general public.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 12	N/A	The State vigorously participates in the formulation of international rules [or norms] for personal information protection, stimulates international exchange and cooperation in the area of personal information protection, and promotes mutual recognition of personal information protection rules [or norms], standards, etc., with other countries, regions, and international organizations.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 13	N/A	Personal information handlers may only handle personal information where they conform to one of the following circumstances: 1. Obtaining individuals' consent; 2. Where necessary to conclude or fulfill a contract in which the individual is an interested party, or where necessary to conduct human resources management according to lawfully formulated labor rules and structures and lawfully concluded collective contracts; 3. Where necessary to fulfill statutory duties and responsibilities or statutory obligations; 4. Where necessary to respond to sudden public health incidents or protect natural persons' lives and health, or the security of their property, under emergency conditions; 5. Handling personal information within a reasonable scope to implement news reporting, public opinion supervision, and other such activities for the public interest; 6. When handling personal information disclosed by persons themselves or otherwise already lawfully disclosed, within a reasonable scope in accordance with the provisions of this Law. 7. Other circumstances provided in laws and administrative regulations. In accordance with other relevant provisions of this Law, when handling personal information, individual consent shall be obtained. However, obtaining individual consent is not required under conditions in items 2 through 7 above.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
Article 14	N/A	Where personal information is handled based on individual consent, said consent shall be given by individuals under the precondition of full knowledge, and in a voluntary and explicit statement. Where laws or administrative regulations provide that separate consent or written consent shall be obtained to handle personal information, those provisions are to be followed. Where a change occurs in the purpose of personal information handling, the handling method, or the categories of handled personal information, the individual's consent shall be obtained again.	Functional	Intersects With	Data Subject Consent	PRI-03	Mechanisms exist to enable data subjects to authorize the collection, receipt, processing, storage, transmission, sharing, updating and/or disposal of their Personal Data (PD), where the data subject is provided, prior to collection, with: (1) Plain language explaining the potential data privacy risks of the authorization; (2) A means to decline the authorization; and (3) Necessary choice and consent-related criteria required by applicable statutory, regulatory and contractual obligations.	5	
Article 15	N/A	Where personal information is handled based on individual consent, individuals have the right to rescind their consent. Personal information handlers shall provide a convenient way to withdraw consent. If an individual rescinds consent, it does not affect the effectiveness of personal information handling activities undertaken on the basis of individual consent before consent was rescinded.	Functional	Intersects With	Revoke Consent	PRI-03.4	Mechanisms exist to allow data subjects to revoke consent to collect, receive, process, store, transmit, share and/or update their Personal Data (PD).	5	
Article 16	N/A	Personal information handlers may not refuse to provide products or services on the basis that an individual does not consent to the handling of their personal information or rescinds their consent, except where handling personal information is necessary for the provision of products or services.	Functional	Intersects With	Product or Service Delivery Restrictions	PRI-03.5	Mechanisms exist to prevent discrimination against a data subject for exercising their legal rights pertaining to modifying or revoking consent, including prohibiting: (1) Refusing products and/or services; (2) Charging different rates for goods and/or services; and (3) Providing different levels of quality.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **China - Personal Information Protection Law of the People's Republic of China (2021)**

Focal Document URL: <https://digi.china.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-2021/>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-chn-pi-pl-2021.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
Article 17	N/A	Personal information handlers shall, before handling personal information, explicitly notify individuals truthfully, accurately, and fully of the following items using clear and easily understood language: 1. The name or personal name and contact method of the personal information handler; 2. The purpose of personal information handling and the handling methods, the categories of handled personal information, and the retention period; 3. Methods and procedures for individuals to exercise the rights provided in this Law; 4. Other items that laws or administrative regulations provide shall be notified. 5. Where a change occurs in the matters provided in the previous paragraph, individuals shall be notified about the change. Where personal information handlers notify the matters as provided in Paragraph 1 through the method of formulating personal information handling rules, the handling rules shall be made public [disclosed] and convenient to read and store.	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	5	
Article 18	N/A	Personal information handlers handling personal information are permitted not to notify individuals about the items provided in Paragraph 1 of the previous Article under circumstances where laws or administrative regulations provide that confidentiality shall be preserved or notification is not necessary. Under emergency circumstances, where it is impossible to notify individuals in a timely manner in order to protect natural persons' lives, health, and the security of their property, personal information handlers shall notify them after the conclusion of the emergency circumstances.	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	5	
Article 19	N/A	Except where laws or administrative regulations provide otherwise, personal information retention periods shall be the shortest period necessary to realize the purpose of the personal information handling.	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless of the method of storage; and (3) Use organization-defined techniques or methods to ensure secure deletion or destruction of PD (including originals, copies and archived records).	5	
Article 20	N/A	Where two or more personal information handlers jointly decide on a personal information handling purpose and handling method, they shall agree on the rights and obligations of each. However, said agreement does not influence an individual's rights to demand any one personal information handler perform under this Law's provisions. Where personal information handlers jointly handling personal information harm personal information rights and interests, resulting in damages, they bear joint liability according to the law.	Functional	Intersects With	Joint Processing of Personal Data (PD)	PRI-07.2	Mechanisms exist to clearly define and communicate the organization's role in processing Personal Data (PD) in the data processing ecosystem.	5	
Article 21	N/A	Where personal information handlers entrust the handling of personal information, they shall conclude an agreement with the entrusted person on the purpose for entrusted handling, the time limit, the handling method, categories of personal information, protection measures, as well as the rights and duties of both sides, etc., and conduct supervision of the personal information handling activities of the entrusted person. Entrusted persons shall handle personal information according to the agreement; they may not handle personal information for handling purposes or in handling methods, etc., in excess of the agreement. If the entrusting contract does not take effect, is void, has been cancelled, or has been terminated, the entrusted person shall return the personal information to the personal information handler or delete it, and may not retain it. Without the consent of the personal information handler, an entrusted person may not further entrust personal information handling to other persons.	Functional	Intersects With	Data Privacy Requirements for Contractors & Service Providers	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	5	
Article 22	N/A	Personal information handlers shall, where it is necessary to transfer personal information due to mergers, separations, dissolution, declaration of bankruptcy, and other such reasons, notify individuals about the receiving party's name or personal name and contact method. The receiving party shall continue to fulfill the personal information handler's duties. Where the receiving side changes the original handling purpose or handling method, they shall notify the individual again as provided in this Law.	Functional	Intersects With	Accounting of Disclosures	PRI-14.1	Mechanisms exist to provide data subjects with an accounting of disclosures of their Personal Data (PD) controlled by: (1) The organization; and/or (2) Relevant third-parties that their PD was shared with.	5	
Article 23	N/A	Where personal information handlers provide other personal information handlers with the personal information they handle, they shall notify individuals about the name or personal name of the recipient, their contact method, the handling purpose, handling method, and personal information categories, and obtain separate consent from the individual. Recipients shall handle personal information within the above mentioned scope of handling purposes, handling methods, personal information categories, etc. Where recipients change the original handling purpose or handling methods, they shall again obtain the individual's consent.	Functional	Intersects With	Accounting of Disclosures	PRI-14.1	Mechanisms exist to provide data subjects with an accounting of disclosures of their Personal Data (PD) controlled by: (1) The organization; and/or (2) Relevant third-parties that their PD was shared with.	5	
Article 24	N/A	When personal information handlers use personal information to conduct automated decision-making, the transparency of the decision-making and the fairness and justice of the handling result shall be guaranteed, and they may not engage in unreasonable differential treatment of individuals in trading conditions such as trade price, etc. Those conducting information push delivery or commercial sales to individuals through automated decision-making methods shall simultaneously provide the option to not target an individual's characteristics, or provide the individual with a convenient method to refuse. When the use of automated decision-making produces decisions with a major influence on the rights and interests of the individual, they have the right to require personal information handlers to explain the matter, and they have the right to refuse that personal information handlers make decisions solely through automated decision-making methods.	Functional	Intersects With	Automated Decision-Making Technology (ADMT) For Data Subject Actions	PRI-19	Mechanisms exist to ensure data subject actions utilizing Automated Decision-Making Technology (ADMT) where computation replaces, or substantially replaces, human decisionmaking, conforms with all applicable statutory, regulatory and/or contractual obligations.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **China - Personal Information Protection Law of the People's Republic of China (2021)**

Focal Document URL: [https://digi.china.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-](https://digi.china.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-2021/)

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-chn-pipl-2021.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
Article 24	N/A	When personal information handlers use personal information to conduct automated decision-making, the transparency of the decision-making and the fairness and justice of the handling result shall be guaranteed, and they may not engage in unreasonable differential treatment of individuals in trading conditions such as trade price, etc. Those conducting information push delivery or commercial sales to individuals through automated decision-making methods shall simultaneously provide the option to not target an individual's characteristics, or provide the individual with a convenient method to refuse. When the use of automated decision-making produces decisions with a major influence on the rights and interests of the individual, they have the right to require personal information handlers to explain the matter, and they have the right to refuse that personal information handlers make decisions solely through automated decision-making methods.	Functional	Intersects With	Automated Decision-Making Technology (ADMT) Transparency	PRI-19.3	Mechanisms exist to provide data subjects with sufficient details of the logic and parameters used by Automated Decision-Making Technology (ADMT) to process the Personal Data (PD) to generate an output with respect to the data subject.	5	
Article 25	N/A	Personal information handlers may not disclose the personal information they handle, except where they obtain separate consent.	Functional	Intersects With	Disclosure of Information	DCH-03.1	Mechanisms exist to restrict the disclosure of sensitive and/or regulated data to authorized parties with a need to know.	5	
Article 26	N/A	The installation of image collection or personal identity recognition equipment in public venues shall occur as required to safeguard public security and observe relevant State regulations, and clear indicating signs shall be installed. Collected personal images and personal distinguishing identity characteristic information can only be used for the purpose of safeguarding public security; it may not be used for other purposes, except where individuals' separate consent is obtained.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
Article 27	N/A	Personal information handlers may, within a reasonable scope, handle personal information that has already been disclosed by the person themselves or otherwise lawfully disclosed, except where the person clearly refuses. Personal information handlers handling already disclosed personal information, where there is a major influence on individual rights and interests, shall obtain personal consent in accordance with the provisions of this Law.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
Article 28	N/A	Sensitive personal information means personal information that, once leaked or illegally used, may easily cause harm to the dignity of natural persons grave harm to personal or property security, including information on biometric characteristics, religious beliefs, specially-designated status, medical health, financial accounts, individual location tracking, etc., as well as the personal information of minors under the age of 14. Only where there is a specific purpose and a need to fulfill, and under circumstances of strict protection measures, may personal information handlers handle sensitive personal information.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
Article 29	N/A	To handle sensitive personal information, the individual's separate consent shall be obtained. Where laws or administrative regulations provide that written consent shall be obtained for handling sensitive personal information, those provisions are to be followed.	Functional	Intersects With	Tailored Consent	PRI-03.1	Mechanisms exist to allow data subjects to modify permission to collect, receive, process, store, transmit, share, update and/or dispose selected attributes of their Personal Data (PD).	5	
Article 30	N/A	Personal information handlers handling sensitive personal information, in addition to the items set out in Article 17, Paragraph 1, of this Law, shall also notify individuals of the necessity and influence on the individual's rights and interests of handling the sensitive personal information, except where this Law provides that it is permitted not to notify the individuals.	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	5	
Article 31	N/A	Where personal information handlers handle the personal information of minors under the age of 14, they shall obtain the consent of the parent or other guardian of the minor. Where personal information handlers handle the personal information of minors under the age of 14, they shall formulate specialized personal information handling rules.	Functional	Intersects With	Parent or Guardian Opt-In Consent For Minors	PRI-03.13	Mechanisms exist to obtain parental or guardian consent for Personal Data (PD) processing actions through reasonable consumer expectations, when the data subject is a minor.	5	
Article 32	N/A	Where laws or administrative regulations provide that relevant administrative licenses shall be obtained or other restrictions apply to the handling of sensitive personal information, those provisions are to be followed.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 33	N/A	This Law applies to State organs' activities of handling personal information; where this Section contains specific provisions, the provisions of this Section apply.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 34	N/A	State organs handling personal information to fulfill their statutory duties and responsibilities shall conduct them according to the powers and procedures provided in laws or administrative regulations; they may not exceed the scope or extent necessary to fulfill their statutory duties and responsibilities.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 35	N/A	State organs handling personal information for the purpose of fulfilling statutory duties and responsibilities shall fulfill notification duties, except where circumstances as provided in Article 18, Paragraph 1, of this Law exist, or where notification will impede State organs' fulfillment of their statutory duties and responsibilities.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 36	N/A	Personal information handled by State organs shall be stored within the mainland territory of the People's Republic of China. If it is truly necessary to provide it abroad, a security assessment shall be undertaken. Relevant authorities may be requested to support and assist with security assessment.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 37	N/A	The provisions of this Law regarding personal information handling by State organs apply to the handling of personal information in order to fulfill statutory duties by organizations authorized by laws and regulations to manage public affairs functions.	Functional	No Relationship	N/A	N/A	N/A	0	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **China - Personal Information Protection Law of the People's Republic of China (2021)**

Focal Document URL: <https://digichina.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-2021/>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-chn-pi-pl-2021.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
Article 38	N/A	Where personal information handlers truly need to provide personal information outside the borders of the People's Republic of China for business or other such requirements, they shall meet one of the following conditions: 1. Passing a security assessment organized by the State cybersecurity and informatization department according to Article 40 of this Law; 2. Undergoing personal information protection certification conducted by a specialized body according to provisions by the State cybersecurity and informatization department; 3. Concluding a contract with the foreign receiving side in accordance with a standard contract formulated by the State cyberspace and informatization department, agreeing upon the rights and responsibilities of both sides; 4. Other conditions provided in laws or administrative regulations or by the State cybersecurity and informatization department. Where treaties or international agreements that the People's Republic of China has concluded or acceded to contain relevant provisions such as conditions on providing personal data outside the borders of the People's Republic of China, those provisions may be carried out. Personal information handlers shall adopt necessary measures to ensure that foreign receiving parties' personal information handling activities reach the standard of personal information protection provided in this Law.	Functional	Intersects With	State-Sponsored Espionage	GOV-13	Mechanisms exist to constrain the host government's ability to leverage the organization's Technology Assets, Applications and/or Services (TAAS) for economic or political espionage and/or cyberwarfare activities.	5	Legal review is recommended. Granting access to Chinese Communist Party (CCP) authorities may result in data compromise.
Article 38	N/A	Where personal information handlers truly need to provide personal information outside the borders of the People's Republic of China for business or other such requirements, they shall meet one of the following conditions: 1. Passing a security assessment organized by the State cybersecurity and informatization department according to Article 40 of this Law; 2. Undergoing personal information protection certification conducted by a specialized body according to provisions by the State cybersecurity and informatization department; 3. Concluding a contract with the foreign receiving side in accordance with a standard contract formulated by the State cyberspace and informatization department, agreeing upon the rights and responsibilities of both sides; 4. Other conditions provided in laws or administrative regulations or by the State cybersecurity and informatization department. Where treaties or international agreements that the People's Republic of China has concluded or acceded to contain relevant provisions such as conditions on providing personal data outside the borders of the People's Republic of China, those provisions may be carried out. Personal information handlers shall adopt necessary measures to ensure that foreign receiving parties' personal information handling activities reach the standard of personal information protection provided in this Law.	Functional	Intersects With	Government Surveillance	CPL-06	Mechanisms exist to constrain the host government from having unrestricted and non-monitored access to the organization's Technology Assets, Applications, Services and/or Data (TAASD) that could potentially violate other applicable statutory, regulatory and/or contractual obligations.	5	Legal review is recommended. Compliance with Chinese Communist Party (CCP) dictates may result in non-compliance with non-Chinese laws, regulations and contractual obligations.
Article 38	N/A	Where personal information handlers truly need to provide personal information outside the borders of the People's Republic of China for business or other such requirements, they shall meet one of the following conditions: 1. Passing a security assessment organized by the State cybersecurity and informatization department according to Article 40 of this Law; 2. Undergoing personal information protection certification conducted by a specialized body according to provisions by the State cybersecurity and informatization department; 3. Concluding a contract with the foreign receiving side in accordance with a standard contract formulated by the State cyberspace and informatization department, agreeing upon the rights and responsibilities of both sides; 4. Other conditions provided in laws or administrative regulations or by the State cybersecurity and informatization department. Where treaties or international agreements that the People's Republic of China has concluded or acceded to contain relevant provisions such as conditions on providing personal data outside the borders of the People's Republic of China, those provisions may be carried out. Personal information handlers shall adopt necessary measures to ensure that foreign receiving parties' personal information handling activities reach the standard of personal information protection provided in this Law.	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
Article 38	N/A	Where personal information handlers truly need to provide personal information outside the borders of the People's Republic of China for business or other such requirements, they shall meet one of the following conditions: 1. Passing a security assessment organized by the State cybersecurity and informatization department according to Article 40 of this Law; 2. Undergoing personal information protection certification conducted by a specialized body according to provisions by the State cybersecurity and informatization department; 3. Concluding a contract with the foreign receiving side in accordance with a standard contract formulated by the State cyberspace and informatization department, agreeing upon the rights and responsibilities of both sides; 4. Other conditions provided in laws or administrative regulations or by the State cybersecurity and informatization department. Where treaties or international agreements that the People's Republic of China has concluded or acceded to contain relevant provisions such as conditions on providing personal data outside the borders of the People's Republic of China, those provisions may be carried out. Personal information handlers shall adopt necessary measures to ensure that foreign receiving parties' personal information handling activities reach the standard of personal information protection provided in this Law.	Functional	Intersects With	Potential Human Rights Abuses	PRI-16	Mechanisms exist to constrain the supply of physical and/or digital activity logs to the host government that can directly lead to contravention of the Universal Declaration of Human Rights (UDHR), as well as other applicable statutory, regulatory and/or contractual obligations.	5	Legal review is recommended. Based on well-publicized human rights abuses in China, providing actual identification of an individual to the Chinese Communist Party (CCP) may result in human rights abuses.

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **China - Personal Information Protection Law of the People's Republic of China (2021)**

Focal Document URL: <https://digi.china.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-2021/>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-chn-pipl-2021.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
Article 39	N/A	Where personal information handlers provide personal information outside of the borders of the People's Republic of China, they shall notify the individual about the foreign receiving side's name or personal name, contact method, handling purpose, handling methods, and personal information categories, as well as ways or procedures for individuals to exercise the rights provided in this Law with the foreign receiving side, and other such matters, and obtain individuals' separate consent.	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	5	
Article 40	N/A	Critical information infrastructure operators and personal information handlers handling personal information reaching quantities provided by the State cybersecurity and informatization department shall store personal information collected and produced within the borders of the People's Republic of China domestically. Where they need to provide it abroad, they shall pass a security assessment organized by the State cybersecurity and informatization department; where laws or administrative regulations and State cybersecurity and informatization department provisions permit that security assessment not be conducted, those provisions are to be followed.	Functional	Intersects With	Data Localization	DCH-26	Mechanisms exist to constrain the impact of "digital sovereignty laws," that require localized data within the host country, where data and processes may be subjected to arbitrary enforcement actions that potentially violate other applicable statutory, regulatory and/or contractual obligations.	5	
Article 41	N/A	Competent authorities of the People's Republic of China, according to relevant laws and treaties or international agreements that the People's Republic of China has concluded or acceded to, or according to the principle of equality and mutual benefit, are to handle foreign judicial or law enforcement authorities' requests regarding the provision of personal information stored domestically. Without the approval of the competent authorities of the People's Republic of China, personal information handlers may not provide personal information stored within the mainland territory of the People's Republic of China to foreign judicial or law enforcement agencies.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 42	N/A	Where foreign organizations or individuals engage in personal information handling acts violating personal information rights and interests of citizens of the People's Republic of China, or harming the national security or public interest of the People's Republic of China, the State cybersecurity and informatization department may put them on a list limiting or prohibiting personal information provision, issue a warning, and adopt measures such as limiting or prohibiting the provision of personal information to them, etc.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 43	N/A	Where any country or region adopts discriminatory prohibitions, limitations or other similar measures against the People's Republic of China in the area of personal information protection, the People's Republic of China may adopt reciprocal measures against said country or region on the basis of actual circumstances.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 44	N/A	Individuals have the right to know and the right to decide relating to their personal information, and have the right to limit or refuse the handling of their personal information by others, unless laws or administrative regulations stipulate otherwise.	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed;	5	
Article 45	N/A	Individuals have the right to consult and copy their personal information from personal information handlers, except in circumstances provided in Article 18, Paragraph 1, or Article 35 of this Law.	Functional	Intersects With	Data Portability	PRI-06.6	Mechanisms exist to format exports of Personal Data (PD) in a structured, machine-readable format that allows data subjects to transfer their PD to another controller without hindrance.	5	
Article 46	N/A	Where individuals request to consult or copy their personal information, and Where individuals discover their personal information is incorrect or incomplete, they have the right to request personal information handlers correct or complete their personal information. Where individuals request to correct or complete their personal information, personal information handlers shall verify the personal information and correct or complete it in a timely manner. Where individuals request to correct or supplement their personal information, personal information handlers shall verify the personal information and correct or supplement it in a timely manner.	Functional	Intersects With	Correcting Inaccurate Personal Data (PD)	PRI-06.1	Mechanisms exist to maintain a process for: (1) Data subjects to have inaccurate Personal Data (PD) maintained by the organization corrected or amended; and (2) Disseminating corrections or amendments of PD to other authorized users of the PD.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **China - Personal Information Protection Law of the People's Republic of China (2021)**

Focal Document URL: <https://digi.china.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-2021/>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-chn-pipl-2021.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
Article 47	N/A	Personal information handlers shall proactively delete personal information where one of the following circumstances occurs; If the personal information handler has not deleted it, individuals have the right to request deletion: 1. The handling purpose has been achieved, is impossible to achieve, or [the personal information] is no longer necessary to achieve the handling purpose; 2. Personal information handlers cease the provision of products or services, or the retention period has expired; 3. The individual rescinds consent; 4. Personal information handlers handled personal information in violation of laws, administrative regulations, or agreements;	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless of the method of storage; and (3) Use organization-defined techniques or methods to ensure secure deletion or destruction of PD (including originals, copies and archived records).	5	
Article 48	N/A	Individuals have the right to request personal information handlers explain personal information handling rules.	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received,	5	
Article 49	N/A	When a natural person is deceased, their next of kin may, for the sake of their own lawful, legitimate interests, exercise the rights provided in this Chapter to consult, copy, correct, delete, etc., the personal information of the deceased, except where the deceased has arranged otherwise before their death.	Functional	Intersects With	Authorized Agent	PRI-03.6	Mechanisms exist to allow data subjects to authorize another person or entity (e.g., authorized agent, proxy, etc.), acting on the data subject's behalf, to make Personal Data (PD) processing decisions.	5	
Article 50	N/A	Personal information handlers shall establish convenient mechanisms to accept and handle applications from individuals to exercise their rights. Where they reject individuals' requests to exercise their rights, they shall explain the reason. Where personal information handlers reject individuals' requests to exercise their rights, individuals may file a lawsuit with a People's Court according to the law.	Functional	Intersects With	Data Subject Feedback Management	PRI-06.4	Mechanisms exist to maintain a process to efficiently and effectively respond to requests, complaints, concerns and/or questions from authenticated data subjects about Personal Data (PD) the organization collects, receives, processes, stores, transmits, shares, updates and/or disposes.	5	
Article 50	N/A	Personal information handlers shall establish convenient mechanisms to accept and handle applications from individuals to exercise their rights. Where they reject individuals' requests to exercise their rights, they shall explain the reason.	Functional	Intersects With	Disclosure Request Rejections	PRI-07.4	Mechanisms exist to reject disclosure requests that are: (1) Unjustified; (2) Unauthenticated or untrustworthy; and/or (3) Unlawful.	5	
Article 50	N/A	Personal information handlers shall establish convenient mechanisms to accept and handle applications from individuals to exercise their rights. Where they reject individuals' requests to exercise their rights, they shall explain the reason. Where personal information handlers reject individuals' requests to exercise their rights, individuals may file a lawsuit with a People's Court according to the law.	Functional	Intersects With	Justification To Reject Disclosure Requests	PRI-07.5	Mechanisms exist to document justifiable reasons for rejecting a data subject's access request for disclosure when the request is: (1) Harassing; (2) Repetitive; (3) Fraudulent; (4) Unjustified; and/or (5) Unlawful.	5	
Article 51	N/A	Personal information handlers shall, on the basis of the personal information handling purpose, handling methods, personal information categories, as well as the influence on individuals' rights and interests, possibly existing security risks, etc., adopt the following measures to ensure personal information handling conforms to the provisions of laws and administrative regulations, and prevent unauthorized access as well as personal information leaks, distortion, or loss:	Functional	Subset Of	Data Privacy Program	PRI-01	Mechanisms exist to facilitate the implementation and operation of data protection controls throughout the data lifecycle to ensure all forms of Personal Data (PD) are processed lawfully, fairly and transparently.	10	
Article 52	N/A	Personal information handlers that handle personal information reaching quantities provided by the State cybersecurity and informatization department shall appoint personal information protection officers, to be responsible for supervising personal information handling activities as well as adopted protection measures, etc. Personal information handlers shall disclose the methods of contacting personal information protection officers, and report the personal names of	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
Article 53	N/A	Personal information handlers outside the borders of the People's Republic of China, as provided in Article 3, Paragraph 2, of this Law, shall establish a dedicated entity or appoint a representative within the borders of the People's Republic of China to be responsible for matters related to the personal information they handle, and are to report the name of the relevant entity or the personal name of the representative and contact method, etc., to the departments fulfilling personal information protection duties and responsibilities.	Functional	Intersects With	Localized Representation	CPL-08	Mechanisms exist to appoint localized representation with a physical presence in localities, as required by applicable laws and/or regulations.	5	
Article 54	N/A	Personal information handlers shall regularly engage in audits of their personal information handling and compliance with laws and administrative regulations.	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **China - Personal Information Protection Law of the People's Republic of China (2021)**

Focal Document URL: <https://digichina.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-2021/>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-chn-pipl-2021.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
Article 55	N/A	When one of the following circumstances is present, personal information handlers shall conduct a personal information protection impact assessment in advance, and record the handling situation: 1. Handling sensitive personal information; 2. Using personal information to conduct automated decision-making; 3. Entrusting personal information handling, providing personal information to other personal information handlers, or disclosing personal information to other personal information handlers, or disclosing personal information to other personal information handlers.	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	5	
Article 56	N/A	The content of the personal information protection impact assessment shall include: 1. Whether or not the personal information handling purpose, handling method, etc., are lawful, legitimate, and necessary;	Functional	Intersects With	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	5	
Article 57	N/A	Where a personal information leak, distortion, or loss occurs or might have occurred, personal information handlers shall immediately adopt remedial measures, and notify the departments fulfilling personal information protection duties and responsibilities and the individuals. The notification shall include the following items: 1. The information categories, causes, and possible harm caused by the leak, distortion, or loss that occurred or might have occurred; 2. The remedial measures taken by the personal information handler and measures individuals can adopt to mitigate harm; 3. Contact method of the personal information handler.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	5	
Article 57	N/A	Where a personal information leak, distortion, or loss occurs or might have occurred, personal information handlers shall immediately adopt remedial measures, and notify the departments fulfilling personal information protection duties and responsibilities and the individuals. The notification shall include the following items: 1. The information categories, causes, and possible harm caused by the leak, distortion, or loss that occurred or might have occurred; 2. The remedial measures taken by the personal information handler and measures individuals can adopt to mitigate harm; 3. Contact method of the personal information handler.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5	
Article 58	N/A	Personal information handlers providing important Internet platform services, that have a large number of users, and whose business models are complex shall fulfill the following obligations: 1. Establish and complete personal information protection compliance systems and structures according to State regulations, and establish an independent body composed mainly of outside members to supervise personal information protection circumstances; 2. Abide by the principles of openness, fairness, and justice; formulate platform rules; and clarify the standards for intra-platform product or service providers' handling of personal information and their personal information protection duties; 3. Stop providing services to product or service providers on the platform that seriously violate laws or administrative regulations in handling personal information; 4. Regularly release personal information protection social responsibility reports, and accept society's supervision.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 59	N/A	Entrusted persons accepting entrusted handling of personal information shall, according to the provisions of this Law and relevant laws and administrative regulations, take necessary measures to safeguard the security of the personal information they handle, and assist personal information handlers in fulfilling the obligations provided in this Law.	Functional	Intersects With	Confidentiality Agreements	HRS-06.1	Mechanisms exist to require Non-Disclosure Agreements (NDAs) or similar confidentiality agreements that reflect the needs to protect data and operational details, or both employees and third-parties.	5	
Article 60	N/A	The State cybersecurity and informatization department is responsible for comprehensive planning and coordination of personal information protection work and related supervision and management work. Relevant State Council departments are responsible for personal information protection, supervision, and management work within their respective scope of duties and responsibilities, according to the provisions of this Law and relevant laws and administrative regulations. County-level and higher people's governments' relevant departments' personal information protection, supervision, and management duties and responsibilities are determined according to relevant State provisions. Departments provided in the previous two Paragraphs are all referred to as departments fulfilling personal information protection duties and responsibilities.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 61	N/A	Departments fulfilling personal information protection duties and responsibilities fulfill the following personal information protection duties and responsibilities: 1. Conducting personal information protection propaganda and education, and guiding and supervising personal information handlers' conduct of	Functional	No Relationship	N/A	N/A	N/A	0	
Article 62	N/A	The State cybersecurity and informatization department coordinates overall the following personal information protection work by the relevant departments: 1. Formulate concrete personal information protection rules and standards; 2. Formulate specialized personal information protection rules and standards for small-scale personal information handlers and new technologies and new applications for handling sensitive personal information, facial recognition, artificial intelligence, etc.; 3. Support the research, development, and broad adoption of secure and convenient electronic identity authentication technology, and promote the construction of public online identity authentication services; 4. Advance the construction of service systems to socialize personal information protection, and support relevant organizations to launch personal information protection evaluation and certification services	Functional	No Relationship	N/A	N/A	N/A	0	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **China - Personal Information Protection Law of the People's Republic of China (2021)**

Focal Document URL: <https://digichina.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-2021/>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-chn-pi-pl-2021.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
Article 63	N/A	When departments fulfilling personal information protection duties and responsibilities fulfill personal information protection duties and responsibilities, they may adopt the following measures: 1. Interviewing relevant concerned parties, and investigating circumstances related to personal information handling activities; 2. Consulting and reproducing a concerned party's contracts, records, and receipts as well as other relevant material related to personal information handling activities; 3. Conducting on-site inspections, and conducting investigations of suspected unlawful personal information handling activities; 4. Inspecting equipment and articles relevant to personal information handling activities; and when there is evidence the equipment or articles are used to engage in illegal personal information handling activities, after reporting to their department's main person responsible in writing and receiving approval, they may seal or confiscate them.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 64	N/A	Where departments fulfilling personal information protection duties and responsibilities discover relatively large risks exist in personal information handling activities or personal information security incidents occur, they may conduct a talk with the personal information handler's legal representative or main person responsible according to regulatory powers and procedures, or require personal information handlers to entrust specialized institutions to conduct compliance audits of their personal information handling activities. Personal information handlers shall adopt measures according to requirements to correct the matter and eliminate the vulnerability. Where departments fulfilling personal information protection duties and responsibilities discover in the course of their duties discover unlawful handling of personal information that is suspected of constituting a crime, they shall promptly transfer the matter to public security authorities for processing according to the law.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 65	N/A	Any organization or individual has the right to file a complaint or report about unlawful personal information handling activities with departments fulfilling personal information protection duties and responsibilities. Departments receiving complaints or reports shall process them promptly and according to the law, and notify the complaining or reporting person of the handling outcome. Departments fulfilling personal information protection duties and responsibilities shall publish contact methods to accept complaints and reports.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 66	N/A	Where personal information is handled in violation of this Law or personal information is handled without fulfilling personal information protection duties in accordance with the provisions of this Law, the departments fulfilling personal information protection duties and responsibilities are to order correction, confiscate unlawful income, and order the provisional suspension or termination of service provision of the application programs unlawfully handling personal information; where correction is refused, a fine of not more than 1 million Yuan is to be additionally imposed; the directly responsible person in charge and other directly responsible personnel are to be fined between 10,000 and 100,000 Yuan. Where the circumstances of the unlawful acts mentioned in the preceding Paragraph are grave, the provincial- or higher-level departments fulfilling personal information protection duties and responsibilities are to order correction, confiscate unlawful income, and impose a fine of not more than 50 million Yuan, or 5% of annual revenue. They may also order the	Functional	No Relationship	N/A	N/A	N/A	0	
Article 67	N/A	Where unlawful acts as provided in this Law occur, they will be entered into credit files as provided by relevant laws and administrative regulations, and be publicized.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 68	N/A	Where State organs fail to fulfill personal information protection duties as provided in this Law, their superior organs or the departments fulfilling personal information protection duties and responsibilities shall order correction; the directly responsible person in charge and other directly responsible persons are to be sanctioned according to the law. Where the personnel of departments fulfilling personal information protection duties commit dereliction of duties, abuse their power, or engage in favoritism, but not yet constituting a crime, they shall be sanctioned according to the law.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 69	N/A	Where the handling of personal information infringes upon personal information rights and interests and results in harm, and personal information handlers cannot prove they are not at fault, they shall bear	Functional	No Relationship	N/A	N/A	N/A	0	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **China - Personal Information Protection Law of the People's Republic of China (2021)**

Focal Document URL: [https://digichina.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-](https://digichina.stanford.edu/work/translation-personal-information-protection-law-of-the-peoples-republic-of-china-effective-nov-1-2021)

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-chn-pipl-2021.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
Article 70	N/A	Where personal information handlers handle personal information in violation of the provisions of this Law, infringing on the rights and benefits of many individuals, the People's Procuratorates, statutorily designated consumer organizations, and organizations designated by the State cybersecurity and informatization department may file a lawsuit with a People's Court according to the law.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 71	N/A	Where a violation of the provisions of this Law constitutes a violation of public security management, public security management punishment shall be imposed according to the law; where it constitutes a crime, criminal liability is to be investigated according to the law.	Functional	No Relationship	N/A	N/A	N/A	0	
Article 72	N/A	This Law does not apply to natural persons handling personal information for personal or family affairs. Where the law contains provisions on personal information handling by people's governments at all levels and their relevant departments and organizations implementing statistical and archival management	Functional	No Relationship	N/A	N/A	N/A	0	
Article 73	N/A	The following terms used in this Law are defined as follows: 1. "Personal information handler" refers to organizations and individuals that, in personal information handling activities, autonomously decide	Functional	No Relationship	N/A	N/A	N/A	0	
Article 74	N/A	This Law shall enter into force on November 1, 2021.	Functional	No Relationship	N/A	N/A	N/A	0	